

A2Z MIS 360

Security Architecture Whitepaper

Version v8.14 · 109 audit gates · For CISO + security review

1. Authentication + Authorization

✓ **Shipped** Primary method: JWT Bearer Token

Source: `utils/api.py`

■ **Designed** TOTP MFA

Designed in v5.x; not yet wired to login flow

→ **Roadmap** SSO SAML 2.0

Planned v9.x; depends on SSO provider integration

→ **Roadmap** SSO OIDC

Planned v9.x

✓ **Shipped** RBAC (role-based access control)

Default roles: 6; granularity: Page-level + API endpoint-level

2. Encryption + Audit Trail

■ **Designed** At rest: AES-256

Standard pattern; production deployment-specific

■ **Designed** In transit: TLS 1.3

Standard pattern; production deployment-specific

✓ **Shipped** Audit trail

Tamper-evident, hash-chained per `audit_log()` helper; retention: 7 years (configurable)

3. Operations Resilience

Per CBK Operations Resilience Guidelines (2019). Locked by audit gate G108.

✓ **Shipped Retry**

Shipped v8.1; attempts: 3; backoff_seconds: [1.0, 3.0, 9.0]; jitter_pct: 0.2; jitter_added: v8

✓ **Shipped Circuit Breaker**

Shipped v8.1; threshold: 5; open_duration_seconds: 60.0; half_open_probe: True

✓ **Shipped Latency Telemetry**

Shipped v8.2;

✓ **Shipped Observability triangle (mode + circuit + latency)**

Which path are we on? | Is the path healthy? | How fast is the path?

4. Compliance Posture

Feature	Status	Notes
CBK PRUDENTIAL	■ Designed	Aligned in charter; per-bank verification needed
CBK OPERATIONS RESILIENCE 2019	✓ Shipped	
DATA PROTECTION ACT 2019	■ Designed	Audit trail + RBAC support; per-bank deployment review needed
IFRS 9	✓ Shipped	utils/ifrs9_engine.py + page 88
IFRS 7	✓ Shipped	utils/ifrs7_engine.py
IFRS 16	✓ Shipped	utils/ifrs16_engine.py
IFRS 15	✓ Shipped	utils/ifrs15_engine.py
BASEL III	✓ Shipped	utils/capital_adequacy.py

Certifications

Feature	Status	Notes
SOC 2 TYPE II	→ Roadmap	Planned; no certification yet awarded
ISO 27001	→ Roadmap	Planned; no certification yet awarded

A2Z does not currently hold SOC 2 or ISO 27001 certifications. References to readiness reflect architectural alignment with the standards' control families, not awarded certifications.

What this document does not claim

This artifact is rendered from registries that the codebase audits on every build. Numbers that appear here trace to a registry path; if a future build changes the registry, the next regeneration of this artifact will reflect the change. To verify the platform's current state, run `python scripts/audit.py`. The list below enumerates what this artifact deliberately does NOT claim — features that are roadmap rather than shipped, integrations that are designed but not deployed, outcomes that are projections rather than measurements.

- Encryption at-rest and in-transit are deployment-specific patterns; A2Z relies on host infrastructure (cloud/on-prem) for actual implementation.
- MFA is designed but not yet wired into the default login flow.
- SAML/OIDC SSO is roadmap, not shipped.
- HSM key-management integration is bank-deployment-specific; A2Z provides hooks but not bundled HSM.
- SOC 2 and ISO 27001 are roadmap goals, not awarded certifications.
- Multi-process state (circuit breaker + latency telemetry shared across gunicorn workers / kubernetes pods) needs Redis backend; v8.x ships single-process pattern, multi-process is v9.x roadmap.